Questionnaire ISRA IT — Application

PARTIE 1 — ÉVALUATION TECHNIQUE PROPRE À L'APPLICATION

Ce questionnaire est destiné au responsable technique de l'application. Il porte sur le logiciel, ses accès, ses interfaces, ses traitements et les contrôles de sécurité qui lui sont propres. L'hébergement fait l'objet de la partie 2, réalisée une seule fois par plateforme partagée puis rattachée aux applications concernées.

Répondez pour la situation actuellement en production. Si un contrôle est assuré par un éditeur ou prestataire, précisez-le et indiquez le justificatif disponible : « géré par un tiers » ne signifie pas « non concerné ». Plusieurs réponses peuvent être retenues seulement lorsque cela est indiqué. Si une réponse n'est pas connue, sélectionnez « Je ne sais pas ».

Filtrage : le Socle commun est toujours affiché. Le choix du modèle d'exploitation active les questions spécifiques. En environnement hybride, activer les deux familles pour les composants concernés.

1. Identification et architecture applicative

Description de l'application et rattachement à l'hébergement

A01. Quel type de solution évaluez-vous ?

Catégorie : Socle commun

Choisir la réponse principale. Préciser, si nécessaire, les composants gérés par l'entreprise et par un fournisseur.

Application développée en interne ou sur mesure	—
Progiciel installé et administré pour l'entreprise	—
Application fournie en tant que service (SaaS)	—
Application hybride, comportant plusieurs types de composants	—
Je ne sais pas	ND

Réponse / précisions : .....

A02. Sur quelle(s) plateforme(s) ou quel(s) environnement(s) d'hébergement l'application fonctionne-t-elle ?

Catégorie : Solution sous maîtrise technique de l'entreprise

Indiquer les identifiants de plateforme à rapprocher du questionnaire « Hébergement », ainsi que leur rôle : production, base de données, préproduction, traitement ou autre.

Réponse / précisions : .....

.....

.....

A03. Un schéma récent décrit-il les composants de l'application et ses principales communications ?

Catégorie : Socle commun

Schéma applicatif : interfaces, API, bases de données, traitements et dépendances. Ne pas confondre avec le schéma d'infrastructure de la plateforme.

Oui, complet et vérifié après les derniers changements importants	0
Oui, mais certaines informations ne sont pas à jour	2
Partiellement	3
Non	5
Je ne sais pas	ND

Réponse / précisions : .....

A04. Quels sont les composants majeurs de l'application et leurs technologies (avec les versions connues) ?

Catégorie : Solution sous maîtrise technique de l'entreprise

Exemples : portail web, application mobile, services métier, API, base de données, traitement planifié, connecteur. Préciser ce qui relève de l'éditeur.

Réponse / précisions : .....

.....

.....

A05. L'application dispose-t-elle d'une fiche à jour dans le référentiel des actifs ou la CMDB ?

Catégorie : Socle commun

Contrôle de gouvernance ; à ne pas confondre avec une vulnérabilité exploitable.

Oui, avec propriétaire, version, dépendances et plateforme d'hébergement à jour	0
Oui, mais certaines informations sont manquantes ou anciennes	2
Non	4
Je ne sais pas	ND

Réponse / précisions : .....

A06. Quels environnements de l'application existent en dehors de la production ?

Catégorie : Socle commun

Choix multiples. L'objectif est d'identifier les environnements concernés par les contrôles applicatifs.

Développement	—
Test ou recette	—
Préproduction	—
Formation ou démonstration	—
Aucun environnement distinct	—
Je ne sais pas	ND

Réponse / précisions : .....

A07. Des données réelles de production sont-elles copiées dans les environnements hors production ?

Catégorie : Socle commun

Si aucun environnement hors production n'existe, sélectionner « Non concerné ».

Non, seules des données fictives ou irréversiblement anonymisées sont utilisées	0
Oui, mais les données sont masquées et les accès maîtrisés	1
Oui, données réelles avec un niveau de protection équivalent à la production	3
Oui, données réelles avec des protections moins strictes	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

A08. Un ou plusieurs composants logiciels propres à l'application ne reçoivent-ils plus de mises à jour de sécurité ?

Catégorie : Solution sous maîtrise technique de l'entreprise

Exemples : framework, moteur applicatif, bibliothèque ou progiciel. Les systèmes et composants communs d'infrastructure sont évalués dans la partie Hébergement.

Aucun composant identifié comme hors support	0
Fin du support prévue dans les 12 prochains mois	2
Au moins un composant hors support avec mesures compensatoires vérifiées	3
Au moins un composant hors support sans protection adaptée	5
Je ne sais pas	ND

Réponse / précisions : .....

A09. Des changements majeurs de l'application sont-ils prévus dans les 12 prochains mois ?

Catégorie : Socle commun

Préciser le projet et la date connue. Une évolution prévue ne remplace pas la vérification de l'état actuel.

Non	—
Oui : changement de version ou de technologie	—
Oui : migration, remplacement ou arrêt	—
Oui : changement de fournisseur ou refonte importante	—
Je ne sais pas	ND

Réponse / précisions : .....

2. Exposition, authentification et autorisations

Accès à l'application

B01. Depuis quels environnements les utilisateurs ou systèmes peuvent-ils accéder à l'application ?

Catégorie : Socle commun

Choix multiples. Ces réponses décrivent l'exposition ; une ouverture Internet n'est pas en elle-même une défaillance de sécurité.

Réseau interne de l'entreprise	—
Accès distant privé (VPN ou réseau privé équivalent)	—
Internet, avec authentification	—
Internet, pour des fonctions volontairement publiques	—
Accès de partenaires par liaison privée ou interface dédiée	—
Je ne sais pas	ND

Réponse / précisions : .....

B02. Quelles interfaces de l'application sont accessibles depuis l'extérieur de l'entreprise ?

Catégorie : Socle commun

Choix multiples. Si des interfaces sont externes, préciser les principales URL, usages ou publics autorisés.

Interface web ou mobile destinée aux utilisateurs	—
API destinée aux partenaires ou clients	—
Interface de dépôt ou de récupération de fichiers	—
Interface d'administration applicative	—
Aucune	—
Je ne sais pas	ND

Réponse / précisions : .....

B03. Quels modes d'authentification permettent de se connecter à l'application ?

Catégorie : Socle commun

Choix multiples. Le mode seul ne permet pas de juger de la maîtrise des accès ; préciser les exceptions et mécanismes de secours.

SSO ou fédération avec l'identité d'entreprise	—
Comptes locaux gérés par l'application	—
Fédération avec l'identité d'un partenaire ou fournisseur	—
Authentification sans compte pour les fonctions publiques	—
Autre mécanisme	—
Je ne sais pas	ND

Réponse / précisions : .....

B04. L'authentification multifacteur (MFA) protège-t-elle les accès qui en ont besoin ?

Catégorie : Socle commun

Évaluer la couverture réelle du MFA, y compris les comptes locaux et les accès de secours. Les exigences peuvent dépendre du contexte de l'application.

Oui, tous les comptes concernés, y compris les accès sensibles	0
Oui, tous les accès à privilèges et externes, avec exceptions justifiées	1
Seulement une partie des accès sensibles	3
Aucun MFA sur des accès sensibles	5
Je ne sais pas	ND

Réponse / précisions : .....

B05. Les droits de connexion et les comptes sont-ils créés, modifiés et retirés lors des arrivées, mobilités et départs ?

Catégorie : Socle commun

Préciser la personne ou l'équipe responsable de l'exécution technique.

Oui, processus maîtrisé, tracé et vérifié	0
Oui, sur demande formalisée mais avec vérification limitée	2
Traitement manuel irrégulier	4
Aucun processus fiable	5
Je ne sais pas	ND

Réponse / précisions : .....

Droits et comptes sensibles

B06. Les rôles et droits fonctionnels de l'application sont-ils définis et limités au besoin de chaque utilisateur ?

Catégorie : Socle commun

Oui, rôles documentés et vérifiés selon le principe du moindre privilège	0
Rôles définis, avec certaines permissions trop étendues	2
Droits attribués principalement au cas par cas sans revue régulière	4
Droits largement ouverts ou identiques pour tous	5
Je ne sais pas	ND

Réponse / précisions : .....

B07. L'application vérifie-t-elle les autorisations avant chaque opération sensible et l'accès aux données concernées ?

Catégorie : Socle commun

Exemples : empêcher un utilisateur de consulter un dossier appartenant à un autre client, de modifier un montant ou d'utiliser une fonction réservée.

Oui, contrôles effectués côté serveur et régulièrement testés	0
Oui, contrôles en place, mais peu ou pas testés	2
Contrôles partiels ou reposant sur l'interface utilisateur	4
Aucun contrôle fiable identifié	5
Je ne sais pas	ND

Réponse / précisions : .....

B08. Lorsque plusieurs clients, entités ou organisations partagent l'application, la séparation de leurs données et droits a-t-elle été testée ?

Catégorie : Socle commun

À répondre seulement si l'application est multi-client ou multi-entité.

Oui, tests documentés et résultats satisfaisants	0
Séparation prévue mais non vérifiée récemment	2
Séparation incomplète ou défaut connu	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

B09. Les fonctions d'administration et les actions métier très sensibles disposent-elles de permissions spécifiques ?

Catégorie : Socle commun

Exemples : gestion des utilisateurs, paramètres critiques, suppression massive, paiement ou validation définitive.

Oui, droits limités, séparés et revus	0
Oui, mais avec certaines autorisations étendues	2
Partiellement	4
Non, elles sont accessibles à des profils non justifiés	5
Je ne sais pas	ND

Réponse / précisions : .....

B10. Comment les comptes d'administration applicative sont-ils protégés ?

Catégorie : Socle commun

Les droits d'administration des serveurs ou du cloud relèvent du questionnaire Hébergement.

Comptes nominatifs, MFA et droits restreints avec suivi des actions	0
Comptes nominatifs et MFA, mais suivi limité	1
Comptes nominatifs sans protection renforcée suffisante	3
Comptes partagés ou privilèges non maîtrisés	5
Je ne sais pas	ND

Réponse / précisions : .....

B11. Les comptes administrateurs et les comptes inutilisés font-ils l'objet de revues et de retraits réguliers ?

Catégorie : Socle commun

Oui, revues périodiques tracées et retraits effectués	0
Oui, mais de manière irrégulière	2
Très rarement	4
Jamais	5
Je ne sais pas	ND

Réponse / précisions : .....

B12. Les comptes utilisés par les interfaces et traitements automatiques sont-ils identifiés et limités aux autorisations nécessaires ?

Catégorie : Socle commun

Oui, inventoriés, propriétaires identifiés et droits revus	0
Oui, inventoriés, mais revues incomplètes	2
Partiellement identifiés ou avec des droits excessifs	4
Non maîtrisés	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

B13. L'accès applicatif des éditeurs, intégrateurs ou prestataires est-il limité, nominatif et traçable ?

Catégorie : Socle commun

Ne pas confondre avec l'accès des prestataires à l'infrastructure, évalué séparément.

Aucun accès de prestataire	0
Accès temporaires autorisés et tracés	1
Accès permanents justifiés, nominatifs et revus	2
Accès permanents insuffisamment revus ou tracés	4
Accès partagés ou non maîtrisés	5
Je ne sais pas	ND

Réponse / précisions : .....

Sessions et mécanismes de secours

B14. Les sessions de connexion expirent-elles après une durée d'inactivité adaptée à la sensibilité de l'application ?

Catégorie : Socle commun

Oui, durée définie et vérifiée	0
Oui, mais durée ou couverture non vérifiée	2
Partiellement	4
Non	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

B15. Une session ou un jeton d'accès peut-il être révoqué rapidement en cas de départ, de changement de droits ou de suspicion de compromission ?

Catégorie : Socle commun

Oui, mécanisme testé et utilisable rapidement	0
Oui, mais avec intervention manuelle ou délai important	2
Révocation partielle ou non vérifiée	4
Non	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

B16. Existe-t-il des comptes locaux ou d'urgence qui permettent de contourner le SSO ou les protections d'authentification habituelles ?

Catégorie : Socle commun

Une exception peut être nécessaire pour la reprise, mais doit être sécurisée.

Non, aucun chemin de connexion alternatif non protégé	0
Oui, exceptions recensées, protégées et vérifiées	1
Oui, exceptions connues mais faiblement contrôlées	4
Oui, accès alternatifs non inventoriés ou non maîtrisés	5
Je ne sais pas	ND

Réponse / précisions : .....

B17. La récupération de compte et la réinitialisation des mots de passe comportent-elles une vérification suffisante de l'identité ?

Catégorie : Socle commun

Oui, processus sécurisé et testé	0
Oui, mais sans vérification récente	2
Procédure manuelle fragile ou partielle	4
Non	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

3. Protection des données et secrets applicatifs

Confidentialité et conservation

C01. Les échanges entre les utilisateurs et l'application sont-ils chiffrés avec des protocoles et configurations appropriés ?

Catégorie : Socle commun

Ne concerne pas les communications entre composants d'infrastructure, examinées avec le questionnaire Hébergement.

Oui, pour tous les accès concernés, vérifié	0
Oui, mais paramètres ou couverture non vérifiés	2
Seulement une partie des échanges	4
Non, des données protégées transitent en clair	5
Je ne sais pas	ND

Réponse / précisions : .....

C02. Les secrets utilisés par l'application (clés d'API, mots de passe techniques, jetons) sont-ils stockés et protégés de manière appropriée ?

Catégorie : Socle commun

Oui, stockage dédié, accès restreints et rotation possible	0
Oui, stockage protégé mais rotation ou suivi incomplet	2
Secrets conservés dans des fichiers ou variables peu protégés	4
Secrets en clair dans le code, des dépôts ou des documents accessibles	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

C03. Les extractions de données depuis l'application sont-elles limitées aux profils autorisés et surveillées selon leur sensibilité ?

Catégorie : Socle commun

Oui, permissions, traçabilité et contrôles des extractions inhabituelles	0
Permissions et journalisation sans contrôle d'anomalie	2
Permissions ou traçabilité partielles	4
Exports non restreints ni tracés	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

C04. Les durées de conservation validées par le métier sont-elles appliquées dans l'application ?

Catégorie : Socle commun

Les durées attendues proviennent du métier ou de la conformité. Préciser si aucune règle n'a été définie.

Oui, archivage ou suppression mis en œuvre et vérifié	0
Oui, mais traitement manuel ou vérification incomplète	2
Partiellement	4
Non, les données sont conservées au-delà des durées prévues	5
Je ne sais pas	ND

Réponse / précisions : .....

C05. L'application permet-elle de rechercher, restituer et, lorsque cela est légalement requis, effacer les données d'une personne ?

Catégorie : Socle commun

Oui, processus complet, maîtrisé et testé	0
Oui, mais avec une intervention manuelle importante	2
Partiellement, certaines données ou copies sont difficiles à traiter	4
Non	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

C06. Les copies de données créées par l'application (exports, rapports, dépôts temporaires) sont-elles recensées et protégées ?

Catégorie : Socle commun

Oui, copies connues, accès maîtrisés et effacement prévu	0
Oui, copies recensées mais protections inégales	2
Copies partiellement recensées	4
Copies non maîtrisées	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

C07. Les messages d'erreur, journaux et fonctions de diagnostic évitent-ils de divulguer des données sensibles ou des secrets ?

Catégorie : Socle commun

Oui, contrôle vérifié sur les environnements concernés	0
Mesures en place, non vérifiées récemment	2
Fuites possibles dans certains cas	4
Données sensibles ou secrets régulièrement exposés	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

C08. Si l'application accepte des fichiers déposés par des utilisateurs ou partenaires, leur contenu fait-il l'objet de contrôles de sécurité ?

Catégorie : Socle commun

Question conditionnelle : documents justificatifs, pièces jointes, contrats, images, fichiers de données.

Oui, types, tailles, accès et contenus malveillants contrôlés	0
Contrôles présents, mais incomplets	2
Contrôles limités au type ou à la taille du fichier	4
Aucun contrôle de sécurité identifié	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

4. Interfaces, API et fiabilité des traitements

Sécurité des échanges entre applications

D01. Les interfaces et flux entrants et sortants sont-ils inventoriés avec leur destination, leur usage et leur responsable ?

Catégorie : Socle commun

Inclure les API, fichiers, transferts automatiques et services appelés. Complète les dépendances indiquées par le Business Owner.

Oui, inventaire complet et maintenu à jour	0
Oui, mais incomplet ou ancien	2
Inventaire partiel	4
Aucun inventaire exploitable	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

D02. Chaque interface dispose-t-elle d'un mécanisme d'authentification adapté, propre à l'échange concerné ?

Catégorie : Socle commun

Oui, mécanismes adaptés et identités techniques distinctes	0
Oui, mais mécanismes ou secrets partagés entre plusieurs flux	2
Authentification faible ou exceptions non justifiées	4
Aucune authentification sur des flux qui devraient être protégés	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

D03. Les données échangées entre applications sont-elles chiffrées pendant leur transport lorsqu'elles le nécessitent ?

Catégorie : Socle commun

Oui, tous les flux concernés sont protégés et vérifiés	0
Oui, mais certains contrôles ne sont pas vérifiés	2
Une partie des flux concernés n'est pas protégée	4
Des flux sensibles circulent en clair sans justification	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

D04. Les échanges importants disposent-ils de mesures assurant l'authenticité et l'intégrité des messages ?

Catégorie : Socle commun

Exemples : signature ou code d'authentification de message, vérification d'émetteur. Un simple chiffrement ou une somme de contrôle non authentifiée ne suffit pas toujours.

Oui, mécanismes adaptés et vérifiés pour tous les flux concernés	0
Oui, mais couverture ou tests incomplets	2
Mesures insuffisantes pour certains flux critiques	4
Aucune garantie fiable lorsque cela est nécessaire	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

D05. Les données reçues par formulaire, API, fichier ou interface sont-elles contrôlées avant traitement ?

Catégorie : Socle commun

Inclure les risques d'injection, les valeurs incohérentes et les données non autorisées.

Oui, validation des formats, des droits et des contenus à risque, avec tests	0
Oui, contrôles en place mais non testés sur tous les flux	2
Contrôles incomplets	4
Absence de validation suffisante	5
Je ne sais pas	ND

Réponse / précisions : .....

D06. Les API vérifient-elles les autorisations de chaque appel, y compris pour l'accès à un dossier ou objet particulier ?

Catégorie : Socle commun

Pour un portail et une API partageant les mêmes services, ne pas déclarer une autorisation vérifiée sans l'avoir également testée côté API.

Oui, contrôles côté serveur et tests d'accès non autorisé	0
Oui, contrôles présents sans tests suffisants	2
Vérifications partielles	4
Absence de vérification fiable	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

D07. Les API ou fonctions exposées disposent-elles de protections contre les sollicitations automatisées abusives ?

Catégorie : Socle commun

Exemples : limitation de débit, contrôle des tentatives, quotas, blocage d'abus. Pour les fonctions concernées seulement.

Oui, limitations et protections adaptées, vérifiées	0
Oui, mesures présentes mais peu ou pas testées	2
Protection partielle	4
Aucune protection adaptée	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

Intégrité des traitements et paramètres

D08. Les traitements automatiques et échanges importants sont-ils supervisés pour détecter les échecs ou dossiers rejetés ?

Catégorie : Socle commun

Oui, événements détectés, alertes reçues et reprise organisée	0
Oui, détection mais traitement des alertes limité	2
Supervision partielle	4
Aucune supervision fiable	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

D09. Après une interruption, les traitements importants peuvent-ils être repris sans perte ni duplication involontaire des opérations ?

Catégorie : Socle commun

Particulièrement important pour les factures, paiements, commandes et mouvements de données.

Oui, mécanismes testés de reprise et de prévention des doublons	0
Oui, procédure existante mais peu testée	2
Reprise principalement manuelle ou incertaine	4
Aucun mécanisme fiable	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

D10. Les modifications des règles métier, paramètres critiques et automatisations sont-elles approuvées, enregistrées et réversibles ?

Catégorie : Socle commun

Oui, validation, traçabilité et retour arrière vérifié	0
Validation et traçabilité, sans retour arrière vérifié	2
Contrôles partiels	4
Modifications non maîtrisées	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

D11. Les traitements planifiés, scripts et connecteurs applicatifs sont-ils recensés, avec des droits d'exécution limités ?

Catégorie : Socle commun

Oui, inventoriés, supervisés et limités en droits	0
Oui, mais supervision ou droits incomplets	2
Partiellement recensés	4
Non maîtrisés	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

5. Journalisation, détection et supervision

E01. Les événements de sécurité de l'application sont-ils enregistrés de façon exploitable ?

Catégorie : Socle commun

L'acheminement et la protection de la plateforme de journaux partagée sont évalués dans la partie Hébergement.

Oui, connexions, échecs, élévations de droits et actions sensibles couverts	0
Oui, mais événements importants manquants	2
Journaux limités aux erreurs techniques	4
Aucune journalisation exploitable	5
Je ne sais pas	ND

Réponse / précisions : .....

E02. Les modifications des données importantes peuvent-elles être retracées (auteur, date, action et élément concerné) ?

Catégorie : Socle commun

Les anciennes et nouvelles valeurs sont utiles selon les cas, mais ne doivent pas être journalisées en clair si elles sont sensibles.

Oui, informations suffisantes et vérifiées	0
Oui, mais seulement pour certains objets ou actions	2
Traçabilité insuffisante	4
Aucune piste d'audit exploitable	5
Je ne sais pas	ND

Réponse / précisions : .....

E03. La durée de conservation des journaux applicatifs répond-elle aux besoins d'enquête et aux obligations définies ?

Catégorie : Socle commun

Ne pas considérer arbitrairement 12 mois comme nécessaires à toute application.

Oui, exigences définies et respectées	0
Exigences définies mais application partielle	2
Durée non justifiée ou insuffisante	4
Aucune conservation utile	5
Je ne sais pas	ND

Réponse / précisions : .....

E04. Des alertes sont-elles prévues en cas de comportements anormaux sur l'application ?

Catégorie : Socle commun

Exemples : connexions inhabituelles, extraction massive, modification en série, échecs répétés.

Oui, cas d'usage définis, actifs et testés	0
Oui, mais couverture ou tests partiels	2
Alertes ponctuelles sans suivi régulier	4
Aucune alerte adaptée	5
Je ne sais pas	ND

Réponse / précisions : .....

E05. Les alertes applicatives importantes sont-elles prises en charge par une équipe identifiée avec des consignes d'intervention ?

Catégorie : Socle commun

Oui, circuit d'alerte, responsables et exercices définis	0
Oui, responsables désignés mais pratique peu éprouvée	2
Prise en charge irrégulière	4
Aucune prise en charge organisée	5
Je ne sais pas	ND

Réponse / précisions : .....

E06. La disponibilité et le bon fonctionnement des fonctions critiques sont-ils supervisés ?

Catégorie : Socle commun

Exemples : capacité à effectuer une opération métier, traitement d'une file de messages ou exécution d'un calcul important.

Oui, supervision fonctionnelle et technique avec alertes traitées	0
Oui, supervision essentiellement technique	2
Surveillance partielle ou manuelle	4
Absence de supervision suffisante	5
Je ne sais pas	ND

Réponse / précisions : .....

6. Vulnérabilités et sécurité du cycle de vie applicatif

Tests, corrections et mises en production

F01. L'application fait-elle l'objet de recherches de vulnérabilités adaptées à son exposition et à ses technologies ?

Catégorie : Socle commun

Tests automatisés, analyses de code, scans ou audits selon le type de solution.

Oui, tests couvrant les composants et interfaces concernés, avec suivi des résultats	0
Oui, couverture incomplète	2
Contrôles très ponctuels	4
Aucune recherche de vulnérabilités identifiée	5
Je ne sais pas	ND

Réponse / précisions : .....

F02. Un test d'intrusion ou un audit technique a-t-il récemment évalué les fonctions et interfaces exposées ?

Catégorie : Socle commun

Indiquer la date, le périmètre, les exclusions et la référence du rapport. Ne pas noter uniquement la date sans tenir compte des évolutions.

Oui, test adapté aux changements et à l'exposition, avec résultats traités	0
Oui, test ancien ou couverture partielle	2
Test très ancien, sans actualisation après changement majeur	4
Aucun test pertinent réalisé	5
Je ne sais pas	ND

Réponse / précisions : .....

F03. Des vulnérabilités applicatives importantes restent-elles connues et non corrigées ?

Catégorie : Socle commun

Une absence de vulnérabilité « connue » n'équivaut pas à une absence de vulnérabilité si les contrôles ne sont pas effectués.

Aucune vulnérabilité importante ouverte dans un périmètre régulièrement contrôlé	0
Vulnérabilités ouvertes avec mesures temporaires et plan de correction suivi	2
Vulnérabilités importantes sans correction rapide ou mesures adaptées	4
Vulnérabilités critiques exposées sans plan maîtrisé	5
Je ne sais pas	ND

Réponse / précisions : .....

F04. Les vulnérabilités applicatives sont-elles corrigées selon des délais adaptés à leur gravité et à l'exposition ?

Catégorie : Socle commun

Oui, délais définis, mesurés et généralement respectés	0
Oui, délais définis mais retards fréquents	2
Traitement irrégulier ou sans priorité claire	4
Aucun processus de correction	5
Je ne sais pas	ND

Réponse / précisions : .....

F05. Les changements applicatifs suivent-ils un processus de validation, de test et de retour arrière ?

Catégorie : Socle commun

Oui, changements tracés, testés, approuvés et retour arrière préparé	0
Oui, mais contrôles de sécurité ou retour arrière incomplets	2
Processus informel	4
Aucun processus maîtrisé	5
Je ne sais pas	ND

Réponse / précisions : .....

F06. Qui peut déployer une nouvelle version ou modifier la configuration de production de l'application ?

Catégorie : Socle commun

Équipe restreinte, autorisations définies et actions tracées	0
Équipe restreinte mais validation ou traçabilité incomplète	2
Droits de déploiement trop étendus	4
Aucun contrôle d'accès approprié	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

Complément : développements internes ou sur mesure

F07. Le développement de l'application suit-il un processus intégrant des exigences de sécurité dès la conception ?

Catégorie : Solution sous maîtrise technique de l'entreprise

Pour les développements internes ou sur mesure uniquement.

Oui, règles formalisées, revues et appliquées	0
Oui, mais couverture incomplète	2
Pratique occasionnelle	4
Aucune démarche identifiée	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

F08. Des analyses automatisées du code et des bibliothèques sont-elles réalisées avant les mises en production ?

Catégorie : Solution sous maîtrise technique de l'entreprise

Exemples : analyse statique du code (SAST), analyse des dépendances (SCA), tests dynamiques (DAST) si adaptés.

Oui, contrôles intégrés aux livraisons et résultats traités	0
Oui, contrôles réalisés ponctuellement	2
Couverture très partielle	4
Aucun contrôle	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

F09. Les bibliothèques, composants tiers et leurs versions sont-ils identifiés afin de repérer les vulnérabilités publiées ?

Catégorie : Solution sous maîtrise technique de l'entreprise

Oui, inventaire maintenu et alertes suivies	0
Oui, inventaire incomplet ou suivi manuel	2
Connaissance partielle des composants	4
Aucun suivi	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

F10. Les dépôts de code et outils de déploiement sont-ils protégés contre les modifications non autorisées ?

Catégorie : Solution sous maîtrise technique de l'entreprise

Oui, accès limités, revues et traçabilité des modifications	0
Oui, mais revues ou protections incomplètes	2
Contrôles partiels	4
Accès et modifications insuffisamment maîtrisés	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

F11. Les secrets de développement et de déploiement sont-ils protégés et peuvent-ils être renouvelés après compromission ?

Catégorie : Solution sous maîtrise technique de l'entreprise

Oui, accès contrôlés, stockage adapté et renouvellement possible	0
Oui, mais protection ou rotation incomplète	2
Secrets répartis dans des outils peu maîtrisés	4
Secrets accessibles en clair ou renouvellement impossible	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

7. Continuité de service et reprise applicative

G01. Quel délai de remise en service complet de l'application a réellement été observé ou démontré lors des tests ?

Catégorie : Socle commun

Préciser le périmètre du test et les dépendances utilisées ; comparer ensuite avec le RTO métier validé, sans noter ce délai isolément.

Moins d'une heure	—
De 1 à moins de 4 heures	—
De 4 à moins de 24 heures	—
De 1 à moins de 3 jours	—
3 jours ou plus	—
Aucune mesure ou aucun essai réalisé	—
Je ne sais pas	ND

Réponse / précisions : .....

G02. Ce délai de reprise de l'application a-t-il été confirmé par un test de bout en bout ?

Catégorie : Socle commun

La restauration d'un serveur ou d'une base ne suffit pas à prouver la reprise du service métier.

Oui, test récent représentatif avec résultats probants	0
Oui, mais test partiel ou ancien	2
Seulement une estimation théorique	4
Aucun test ou élément de preuve	5
Je ne sais pas	ND

Réponse / précisions : .....

G03. Quelle quantité de données récentes peut effectivement être perdue lors d'une reprise de l'application ?

Catégorie : Socle commun

Indiquer le point de reprise réellement démontré et le comparer plus tard avec l'exigence métier (RPO cible).

Aucune perte constatée ou démontrée	—
Moins d'une heure	—
De 1 à moins de 4 heures	—
De 4 à moins de 24 heures	—
24 heures ou plus	—
Non mesurée	—
Je ne sais pas	ND

Réponse / précisions : .....

G04. Un plan précise-t-il comment restaurer l'application, ses paramètres et ses connexions essentielles ?

Catégorie : Socle commun

Oui, procédure documentée et testée	0
Oui, procédure existante mais peu ou non testée	2
Procédure partielle	4
Aucune procédure	5
Je ne sais pas	ND

Réponse / précisions : .....

G05. En cas de défaillance d'un service partagé indispensable (identité, API, base, DNS), une solution de secours applicative existe-t-elle ?

Catégorie : Socle commun

Préciser les dépendances : leur sécurisation technique relève aussi de la plateforme.

Oui, solution testée pour les dépendances critiques	0
Oui, solution prévue mais non testée	2
Mode de secours seulement pour certaines dépendances	4
Aucune solution pour des dépendances critiques	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

G06. La reprise de l'application permet-elle de vérifier la cohérence des données et le résultat des traitements critiques ?

Catégorie : Socle commun

Oui, vérifications définies et testées	0
Oui, vérifications existantes mais incomplètes	2
Vérifications manuelles incertaines	4
Aucune vérification fiable	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

G07. La couverture du support applicatif (horaires, permanence, prestataire) est-elle compatible avec les besoins de disponibilité métier ?

Catégorie : Socle commun

Comparer aux besoins du BO, notamment durant les périodes critiques.

Oui, modalités connues et adaptées aux besoins	0
Oui, mais certaines plages ou responsabilités ne sont pas couvertes	2
Couverture insuffisante	4
Aucun support organisé	5
Je ne sais pas	ND

Réponse / précisions : .....

8. Fournisseurs et assurance des contrôles applicatifs

H01. Quels éditeurs, intégrateurs ou prestataires interviennent dans la maintenance, l'exploitation ou le support de l'application ?

Catégorie : Socle commun

Indiquer leurs rôles et les prestations concernées. Ne pas inclure ici les fournisseurs propres à la plateforme d'hébergement, sauf responsabilité partagée.

Réponse / précisions : .....

.....

H02. Les responsabilités respectives de l'entreprise et de chaque fournisseur en matière de sécurité applicative sont-elles définies ?

Catégorie : Socle commun

Oui, responsabilités documentées et connues des équipes	0
Oui, mais partage incomplet sur certains contrôles	2
Rôles essentiellement supposés ou informels	4
Aucune répartition claire	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

H03. Le contrat ou les engagements du fournisseur couvrent-ils les exigences de sécurité pertinentes pour l'application ?

Catégorie : Socle commun

Exemples : sécurité des accès, traitement des vulnérabilités, notification d'incident, disponibilité, réversibilité, droits d'audit.

Oui, exigences proportionnées, documentées et suivies	0
Oui, mais plusieurs exigences importantes manquent	2
Engagements vagues ou non vérifiés	4
Aucun engagement formalisé	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

H04. Les assurances de sécurité du fournisseur applicatif ont-elles été examinées et leur périmètre vérifié ?

Catégorie : Socle commun

Exemples : rapport SOC 2, certification ISO 27001 du SMSI avec son périmètre, audit de sécurité. La certification d'un fournisseur ne prouve pas automatiquement la sécurité de toutes les fonctionnalités.

Oui, rapport ou attestation récente avec périmètre pertinent vérifié	0
Oui, mais document ancien ou périmètre incomplet	2
Simple déclaration commerciale du fournisseur	4
Aucun élément d'assurance examiné	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

H05. Les écarts de sécurité identifiés chez le fournisseur applicatif sont-ils suivis jusqu'à leur correction ?

Catégorie : Socle commun

Oui, responsables, échéances et preuves de traitement identifiés	0
Oui, suivi partiel	2
Écarts connus sans suivi satisfaisant	4
Aucun suivi	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

H06. Le fournisseur applicatif est-il tenu de signaler les incidents affectant le service ou les données dans les délais nécessaires ?

Catégorie : Socle commun

Oui, délais et modalités adaptés aux obligations de l'entreprise	0
Oui, engagement existant mais insuffisamment précis	2
Notification laissée à la discrétion du fournisseur	4
Aucune obligation identifiée	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

H07. Les données et configurations nécessaires au changement de solution peuvent-elles être récupérées dans un format exploitable ?

Catégorie : Socle commun

Oui, dispositif de réversibilité documenté et testé	0
Oui, prévu contractuellement mais non testé	2
Restitution partielle ou difficile	4
Aucune réversibilité exploitable	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

9. Gouvernance, incidents et justificatifs applicatifs

I01. Quels audits, contrôles ou évaluations de sécurité récents couvrent effectivement cette application ?

Catégorie : Socle commun

Indiquer date, périmètre, référence et principaux points non couverts. L'absence d'audit ne constitue pas automatiquement une faille, mais limite le niveau d'assurance.

Réponse / précisions : .....

.....

I02. Les constats importants d'audit ou de test de sécurité sont-ils traités avec un plan suivi ?

Catégorie : Socle commun

Aucun constat important ouvert après contrôles appropriés	0
Constats suivis avec responsables et échéances	2
Constats importants en retard ou mal suivis	4
Constats critiques sans traitement	5
Non concerné	NA
Je ne sais pas	ND

Réponse / précisions : .....

I03. Des dérogations aux règles de sécurité ou des risques acceptés concernent-ils l'application ?

Catégorie : Socle commun

Indiquer les références des acceptations de risque et les mesures compensatoires ; ne pas les compter deux fois dans un score.

Aucun connu	—
Oui, dérogations approuvées, documentées et limitées dans le temps	—
Oui, dérogations informelles ou sans échéance	—
Je ne sais pas	ND

Réponse / précisions : .....

I04. Existe-t-il une procédure de traitement des incidents de sécurité prenant en compte cette application ?

Catégorie : Socle commun

Oui, rôles, actions et escalade définis et testés	0
Oui, procédure définie mais non testée	2
Procédure incomplète	4
Aucune procédure applicable	5
Je ne sais pas	ND

Réponse / précisions : .....

I05. Des incidents de sécurité, pertes de données ou pannes majeures ont-ils affecté l'application au cours des trois dernières années ?

Catégorie : Socle commun

Préciser les causes identifiées, les effets et les actions correctives. Un incident ancien n'est pas à lui seul une note de risque.

Non	—
Oui, incident de sécurité	—
Oui, panne ou perte de données majeure	—
Oui, plusieurs catégories d'incidents	—
Je ne sais pas	ND

Réponse / précisions : .....

I06. Quels documents permettent de confirmer les réponses importantes et quels points restent à vérifier ?

Catégorie : Socle commun

Exemples : dossier d'architecture applicative, tests des accès, résultat de pentest, registre des interfaces, compte-rendu de reprise, rapport fournisseur. Pour les points en attente, indiquer le responsable pressenti.

Réponse / précisions : .....

.....

ANNEXE — GLOSSAIRE ET RÈGLES DE CATÉGORISATION

Objectif

Afficher uniquement les questions pertinentes pour le modèle d'exploitation applicatif, sans masquer les risques communs aux services SaaS et aux applications administrées par l'entreprise.

Catégories

Catégorie	Définition et périmètre
Socle commun	Questions pertinentes quel que soit le mode d'exploitation. Toujours affichées ; cette catégorie est exclusive et ne possède aucune sous-catégorie.
Service applicatif exploité par un éditeur	Service SaaS exploité principalement par son éditeur. Les contrôles techniques sont exa au moyen des configurations accessibles au client et des preuves ou engagements du fournisseur.
Solution sous maîtrise technique de l'entreprise	Logiciel, progiciel ou composant applicatif administré ou développé sous la responsabili technique de l'entreprise, directement ou par un prestataire, y compris en IaaS/PaaS.

Règles de filtrage

1. Le Socle commun s'affiche systématiquement, sans autre catégorie ni sous-catégorie.

2. Une question spécifique s'affiche dès qu'au moins une de ses catégories est sélectionnée (logique OU). Une question n'apparaît jamais deux fois.

3. Pour une application hybride (SaaS et composants gérés par l'entreprise), sélectionner les deux familles.

4. « Contrôle assuré par le fournisseur » n'équivaut pas à « Non concerné » : rechercher des preuves adaptées. Les options de réponse et notes d'origine sont conservées.

Bilan de la classification

82 questions d'origine conservées : 74 dans le Socle commun ; 8 spécifiques à la maîtrise technique ; 0 exclusivement SaaS.

L'absence de question exclusivement SaaS n'est pas un oubli : les questions actuelles sur les fournisseurs (H01 à H07) peuvent aussi concerner un progiciel non-SaaS maintenu ou exploité par un tiers. Les réserver au SaaS masquerait des risques pertinents.

Questions ciblées « Maîtrise technique de l'entreprise »

A02 — Rattachement aux plateformes évaluées dans le questionnaire Hébergement.
A04 — Composants et versions techniques directement gérés.
A08 — Fin de support des composants logiciels sous maîtrise technique.
F07 — Exigences de sécurité dans le développement interne ou sur mesure.
F08 — Analyses automatisées du code et des dépendances avant livraison.
F09 — Inventaire et suivi des bibliothèques et composants tiers.
F10 — Protection des dépôts de code et outils de déploiement.
F11 — Protection des secrets liés au développement et au déploiement.

Attention aux applications SaaS avec extensions, scripts, API ou connecteurs développés en interne : les questions relatives à ces composants doivent également être évaluées, en activant la famille « maîtrise technique » pour la partie concernée.